

WEB APPLICATION VULNERABILITY ASSESSMENT REPORT

Web Appllication Assessment Using
Nmap & OWASP ZAP

Prepared By
Tamil Selvan

Internship
Future Interns – Cyber Security I

CIN ID
FIT/JUL26/CS9813



Date
July 2026

Target Website
<https://testphp.vulnweb.com>



Executive Summary

This report presents a passive vulnerability assessment of the web application `testphp.vulnweb.com` using Nmap, OWASP ZAP, and Qualys SSL Labs. The assessment was conducted to understand the application's security posture without exploiting any vulnerabilities. The observations and results are documented along with recommendations to improve web application security.





Assessment Overview

Purpose

To evaluate the security of the web application using passive assessment techniques.

Scope

- Passive assessment only
- No exploitation
- No brute-force attacks
- No DoS testing

Approach

The assessment was performed using Nmap, OWASP ZAP, and SSL Labs to identify potential security issues.





Tools Used

Tool	Purpose
Nmap	Network and Port Scanning
OWASP ZAP	Passive Web Security Assessment
SSL Labs	SSL/TLS Security Analysis
Browser Developer Tools	Header and Resource Inspection



Methodology

- The vulnerability assessment was performed using passive security assessment techniques. The following steps were followed:
- Selected a public test website.
- Performed network scanning using Nmap.
- Reviewed the website using OWASP ZAP (Passive Assessment).
- Analysed SSL/TLS configuration using Qualys SSL Labs.
- Documented the findings and provided security recommendations.

Target Website



Nmap Scan



OWASP ZAP



SSL Analysis



Findings



Recommendations



Tool Used

Nmap

- Command Used
- `nmap testphp.vulnweb.com`

Observation

- The target host was reachable.
- The scan identified the target IP address.
- The scanned ports were filtered, indicating firewall protection.

Risk Level

- Low

Recommendation

- Maintain firewall rules and regularly monitor exposed network services.
- 

screen shot

```
Microsoft Windows [Version 10.0.26100.7171]
(c) Microsoft Corporation. All rights reserved.

C:\Users\N.Tmailchelvan>nmap testphp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-23 13:48 +0530
Stats: 0:00:16 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.05% done; ETC: 13:49 (0:00:09 remaining)
Stats: 0:00:19 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 74.10% done; ETC: 13:48 (0:00:04 remaining)
Stats: 0:00:21 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 84.65% done; ETC: 13:48 (0:00:02 remaining)
Stats: 0:00:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 96.20% done; ETC: 13:48 (0:00:01 remaining)
Stats: 0:00:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 98.85% done; ETC: 13:48 (0:00:00 remaining)
Stats: 0:00:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 99.99% done; ETC: 13:48 (0:00:00 remaining)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.14s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 23.39 seconds

C:\Users\N.Tmailchelvan>
```



OWASP ZAP Assessment

Tool Used:

- OWASP ZAP 2.17.0

Assessment Type:

- Passive Web Application Security Assessment

Objective:

- To identify potential web application security issues using passive analysis without performing active attacks.

Observation:

- An attempt was made to perform a passive assessment using OWASP ZAP. However, the target website (testphp.vulnweb.com) was unavailable during the assessment, resulting in a connection timeout. Therefore, no scan results were generated.

Status:

- Assessment Not Completed (Target Unreachable)

Recommendation:

- Repeat the passive assessment when the target website becomes available to collect and analyse security findings.



OWASP ZAP screen shot

```
org.apache.hc.client5.http.HttpHostConnectException]: Connect to https://testphp.vulnweb.com:443 [testphp.vulnweb.com/44.228.249.3, vulnweb.com/64:ff9b:0:0:0:0:2ce4:f903] failed: Connection timed out: getsockopt
```

```

:
hc.client5.http.HttpHostConnectException: Connect to https://testphp.vulnweb.com:443 [testphp.vulnweb.com/44.228.249.3, testphp.vulnweb.com/64:ff9b:0:0:0:0:2ce4:f903] failed: Connection timed out: getsockopt
java.base/sun.nio.ch.Net.pollConnect(Native Method)
java.base/sun.nio.ch.Net.pollConnectNow(Net.java:628)
java.base/sun.nio.ch.NioSocketImpl.timedFinishConnect(NioSocketImpl.java:540)
java.base/sun.nio.ch.NioSocketImpl.connect(NioSocketImpl.java:583)
java.base/java.net.SocksSocketImpl.connect(SocksSocketImpl.java:282)
java.base/java.net.Socket.connect(Socket.java:665)
org.apache.hc.client5.http.ssl.SSLConnectionSocketFactory.lambda$connectSocket$0(SSLConnectionSocketFactory.java:232)
java.base/java.security.AccessController.doPrivileged(AccessController.java:251)
org.apache.hc.client5.http.ssl.SSLConnectionSocketFactory.connectSocket(SSLConnectionSocketFactory.java:231)
org.zaproxy.addon.network.internal.client.apachev5.SslConnectionSocketFactory.connectSocket(SslConnectionSocketFactory.java:195)
org.apache.hc.client5.http.impl.io.DefaultHttpClientConnectionOperator.connect(DefaultHttpClientConnectionOperator.java:181)
org.apache.hc.client5.http.impl.io.ZapHttpClientConnectionOperator.connect(ZapHttpClientConnectionOperator.java:95)
org.apache.hc.client5.http.impl.io.PoolingHttpClientConnectionManager.connect(PoolingHttpClientConnectionManager.java:447)
org.apache.hc.client5.http.impl.classic.InternalExecRuntime.connectEndpoint(InternalExecRuntime.java:162)
org.apache.hc.client5.http.impl.classic.InternalExecRuntime.connectEndpoint(InternalExecRuntime.java:172)
org.apache.hc.client5.http.impl.classic.ConnectExec.execute(ConnectExec.java:142)
org.apache.hc.client5.http.impl.classic.ExecChainElement.execute(ExecChainElement.java:51)
org.apache.hc.client5.http.impl.classic.ZapProtocolExec.execute(ZapProtocolExec.java:179)
org.apache.hc.client5.http.impl.classic.ExecChainElement.execute(ExecChainElement.java:51)
org.apache.hc.client5.http.impl.classic.ZapHttpRequestRetryExec.execute(ZapHttpRequestRetryExec.java:81)
org.apache.hc.client5.http.impl.classic.ExecChainElement.execute(ExecChainElement.java:51)
org.apache.hc.client5.http.impl.classic.ZapInternalHttpClient.doExecute(ZapInternalHttpClient.java:173)
org.apache.hc.client5.http.impl.classic.CloseableHttpClient.execute(CloseableHttpClient.java:245)
org.apache.hc.client5.http.impl.classic.CloseableHttpClient.execute(CloseableHttpClient.java:188)
org.zaproxy.addon.network.internal.client.apachev5.HttpSenderApache.sendImpl0(HttpSenderApache.java:486)
org.zaproxy.addon.network.internal.client.apachev5.HttpSenderApache.sendImpl(HttpSenderApache.java:365)
org.zaproxy.addon.network.internal.client.apachev5.HttpSenderApache.sendImpl(HttpSenderApache.java:116)
org.zaproxy.addon.network.internal.client.BaseHttpSender.sendRateLimited(BaseHttpSender.java:415)
org.zaproxy.addon.network.internal.client.BaseHttpSender.sendAuthenticated(BaseHttpSender.java:383)
org.zaproxy.addon.network.internal.client.BaseHttpSender.sendNoRedirections(BaseHttpSender.java:351)
org.zaproxy.addon.network.internal.client.BaseHttpSender.send(BaseHttpSender.java:307)
org.zaproxy.addon.network.internal.client.BaseHttpSender.sendAndReceive(BaseHttpSender.java:278)
org.zaproxy.addon.network.internal.client.BaseHttpSender.sendAndReceive(BaseHttpSender.java:234)
org.parosproxy.paros.network.HttpSender.sendImpl(HttpSender.java:536)
```



SSL/TLS Assessment

Tool Used:

- Qualys SSL Labs

Observation:

- The SSL assessment could not be completed because the target server was unreachable during testing.

Risk Level:

- Informational

Recommendation:

- Reassess the SSL/TLS configuration when the website becomes available.



SSL/TLS screens hott

 **Qualys** SSL Labs

HomeProjectsQualys Free TrialContact

You are here: [Home](#) > [Projects](#) > [SSL Server Test](#) > testphp.vulnweb.com

SSL Report: testphp.vulnweb.com (44.228.249.3)

Assessed on: Fri, 24 Jul 2026 08:26:39 UTC | **HIDDEN** | [Clear cache](#)[Scan Another »](#)

Assessment failed: Unable to connect to the server

Known Problems

There are some errors that we cannot fix properly in the current version. They will be addressed in the next generation version, which is currently being developed.

- **No secure protocols supported** - if you get this message, but you know that the site supports SSL, wait until the cache expires on its own, then try again, making sure the hostname you enter uses the "www" prefix (e.g., "www.ssllabs.com", not just "ssllabs.com").
- **no more data allowed for version 1 certificate** - the certificate is invalid; it is declared as version 1, but uses extensions, which were introduced in version 3. Browsers might ignore this problem, but our parser is strict and refuses to proceed. We'll try to find a different parser to avoid this problem.
- **Failed to obtain certificate and Internal Error** - errors of this type will often be reported for servers that use connection rate limits or block connections in response to unusual traffic. Problems of this type are very difficult to diagnose. If you have access to the server being tested, before reporting a problem to us, please check that there is no rate limiting or IDS in place.
- **NetScaler issues** - some NetScaler versions appear to reject SSL handshakes that do not include certain suites or handshakes that use a few suites. If the test is failing and there is a NetScaler load balancer in place, that's most likely the reason.
- **Unexpected failure** - our tests are designed to fail when unusual results are observed. This usually happens when there are multiple TLS servers behind the same IP address. In such cases we can't provide accurate results, which is why we fail.



Findings & Risk Assessment

Finding	Risk Level	Status
Target Host Reachable (Nmap)	Low	Completed
Filtered Network Ports	Low	Observed
SSL/TLS Assessment	Informational	Server Unreachable
OWASP ZAP Passive Assessment	Informational	Connection Timeout





Findings & Risk Assessment

Overall Risk

Low

Assessment Status

The assessment was performed using passive security testing techniques. No active attacks or exploitation were conducted during the assessment.





Recommendations

- Based on the assessment, the following security recommendations are suggested to improve the overall security of the web application:
- Enable and maintain proper firewall protection.
- Regularly update the web server and application software.
- Implement HTTP security headers where applicable.
- Configure SSL/TLS securely and use a valid SSL certificate.
- Perform regular vulnerability assessments and security reviews.
- Monitor the web application for security issues and apply timely patches.

Canva Design

-  Firewall Protection
 -  Regular Updates
 -  SSL/TLS Security
 -  Security Headers
 -  Regular Security Testing
 -  Patch Management
- 



conclusion

The vulnerability assessment was conducted using passive security assessment techniques with tools such as Nmap, OWASP ZAP, and Qualys SSL Labs. The assessment provided valuable insights into the security posture of the target web application without performing any active attacks or exploitation.

The findings and recommendations presented in this report can help improve the overall security of the web application. Regular security assessments and timely updates are essential to maintain a secure web environment.

References

1. OWASP Foundation. OWASP ZAP Documentation. <https://www.zaproxy.org/>
 2. Nmap Project. Nmap Reference Guide. <https://nmap.org/>
 3. Qualys SSL Labs. SSL Server Test. <https://www.ssllabs.com/ssltest/>
 4. OWASP Web Security Testing Guide (WSTG). <https://owasp.org/www-project-web-security-testing-guide/>
- 